ĐẠI HỌC BÁCH KHOA HÀ NỘI
VIỆN CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG

Nhập môn An toàn thông tin

Chương 6. **Xác thực định danh**

Xác thực định danh

- Cơ sở bài toán xác thực
- Xác thực bằng mật khẩu
- Giao thức Hỏi-Đáp
- Xác thực sinh trắc
- Xác thực qua vị trí
- Các phương pháp phức hợp

Cơ sở xác thực định danh

- Xác thực định danh: Gắn định danh với thực thể.
  - Danh tinh gắn với thực thể ngoài
  - Các chủ thể số trong hệ thống tính toán (các tiến trinh, ...)
- Note:
  - Xác thực thông điệp là vấn đề khác và đã đề cập tới trong phần hàm băm.
- Thiết lập định danh:
  - Một trong những biện pháp sau:
    - Thông tin mà thực thể biết (mật khẩu)
    - Các vật mà thực thể sở hữu (*vd.* Thẻ căn cước, thẻ thông minh, ...)
    - Các thuộc tính mà thực thể có (*vd.* vân tay, đặc trưng của võng mạc, ...)
    - Vị trí của chủ thể (*vd*. Như vị trí đứng trước một thiết bị đầu cuối)

Hệ thống xác thực định danh

- Bộ 5:(*A*, *C*, *F*, *L*, *S*)
  - *A – a set:* thông tin xác thực của chủ thể
  - *C – a set:* thông tin được lưu trữ trong hệ thống dung để kiểm chứng thông tin xác thực
  - *F:* tập các hàm bổ trợ: $f : A \rightarrow C$
    - *Để xác định các thông tin phụ trợ từ thông tin của thực thể*
  - *L:* hàm xác thực để xác thực chủ thể
  - *S:* hàm cho phép chủ thể tạo hoặc bổ sung thông tin trong A hoặc C

Ví dụ

- Hệ thống mật khẩu với mật khẩu lưu trữ online dưới dạng bản rõ
  - *A – tập các xâu mật khẩu* s
  - *C = A*
  - *F* tập đơn phần tử các hàm thực thể { *I* }
  - *L* hàm kiểm tra mật khẩu { *eq* }
  - *S* hàm dung để thiết lập hay thay đổi mật khẩu

Mật khẩu

- Là chuỗi ký tự
  - Ví dụ: 10 ký tự số, chuỗi ký tự, , ...
  - Sinh ngẫu nhiên (do người sử dụng, do hệ thống, ...)
- Chuỗi từ
  - Ví dụ: chuỗi mật khẩu
- Các thuật toán
  - Ví dụ: giao thức hỏi/đáp, mật khẩu một lần

Lưu trữ mật khẩu

- Lưu trữ dạng bản rõ
  - Nếu tập mật khẩu bị tấn công, tất cả các mật khẩu sẽ bị lộ
- Tệp được mã mật
  - Cần có quá trình giải mã, khóa giải mã được lưu trong bộ nhớ
  - Làm giảm độ phức tạp thực hiện quá trinh mã hóa, giải mã.

- Giải pháp: lưu trữ mã băm một chiều của mật khẩu
  - Khi nhận được file lưu mật khẩu, bên tấn công phải đoán mật khẩu hoặc phải tính ngược lại giá trị băm

Ví dụ: Unix

- Theo định nghĩa, bộ 5 (*A*, *C*, *F*, *L*, *S*)
  - *Tập hợp A:* thông tin xác định thực thể
    - *A* = { xâu gồm 8 ký tự hoặc ít hơn }
  - *Tập C :* thông tin lưu trong hệ thống máy tinh và dùng để kiểm tra thông tin xác thực.
    - *C* = {giá trị băm của mật khẩu}
  - *Tập F:* tập các hàm bổ trợ $f : A \rightarrow C$
    - *F* = { các phiên bản biến thể của DES }
  - *L:* hàm xác thực, để xác minh thực thể
    - *L* = { *login*, *su*, … }
  - *S:* hàm cho phép thực thể tạo, mở rộng thông tin trong các tập *A* hoặc *C*
    - *S* = { *passwd*, *nispasswd*, *passwd+*, … }

Tấn công vào mật khẩu

- Mục tiêu: xác định $a \in A$ sao cho:
  - Với một hàm $f \in F$ nào đó, $f(a) = c \in C$
  - c sẽ được coi là tương ứng với thực thể.
- Hai cách để xác định a có thỏa mãn các yêu cầu này hay không :
  - Tính f(a) với tập hợp các giá trị của a cho tới khi thanh công
  - Gọi hàm I(a) cho tới khi thành công (I(a) trả lại giá trị true)

Ngăn chặn tấn công

- Cách ngăn chặn tấn công:
  - Ẩn một trong các giá trị của *a*, *f*, hoặc *c*
    - Ngăn chặn các tấn công hiển nhiên vào các đối tượng trên
    - Ví dụ: UNIX/Linux giấu các file mật khẩu:
      - Giấu *c*'s
  - Ngăn chặn mọi truy cập vào tất cả $l \in L$ hoặc kết quả của $l(a)$
    - Ngăn kẻ tấn công biết được việc dự đoán thành công hay không.
    - Ví dụ: ngăn chặn mọi truy cập vào tài khoản từ ngoài mạng.
      - Ngăn chặn việc biết được kết quả của *l* (hoặc truy cập vào *l*)

Tấn công từ điển

- Tấn công thử-sai từ danh sách các mật khẩu tiềm năng
  - *Off-line*: biết *f và c*'s, và thử lặp lại việc đoán các giá trị $g \in A$ cho tới khi hết danh sách hoặc đoán ra mật khẩu.
    - Ví dụ: *crack*, *john-the-ripper*
  - *On-line*: Có quyền truy cập tới các hàm trong *L* và đoán *g* cho tới khi có một *l*(*g*) thanh công.
    - Ví dụ: thử truy cập và log in bằng cách đoan mật khẩu

Xác suất tấn công thanh công theo khoảng thời gian

Công thức Anderson:

- *P* xác suất đoán mật khẩu trong một khoảng thời gian
- *G* số lần thử đoán trong một đơn vị thời gian
- *T* số lượng các khoảng thời gian
- *N* số lượng mật khẩu có thể có (|*A*|)
- Khi đó:

$$P \geq TG/N$$

Ví dụ

- Mục tiêu
  - Mật khẩu tạo từ bảng gồm 96 ký tự
  - Có thể kiểm tra 10^4 giá trị phỏng đoán trong 1 giây
  - Xác suất thành công: 0.5 trong khoảng thời gian 365 ngày
  - Kích thước mật khẩu tối thiểu phải bằng bao nhiêu ?
- Lời giải
  - $N \geq TG/P = (365 \times 24 \times 60 \times 60) \times 10^4 / 0.5 = 6.31 \times 10^{11}$
  - Lựa chọn s sao cho $\Sigma^s_{j=0}\ 96^j \geq N$
  - Khi đó $s \geq 6$, có nghĩa là mật khẩu phải dài ít nhất là 6 ký tự

Lựa chọn mật khẩu

- Lựa chọn ngẫu nhiên
  - Bất kỳ mật khẩu nào từ *A* đều có khả năng lựa chọn như nhau
- Mật khẩu phát âm được
- Người sử dụng lựa chọn mật khẩu

Mật khẩu phát âm được

- Tạo sinh các âm vị ngẫu nhiên
  - Âm vị: là các đơn vị phát âm như: *cv*, *vc*, *cvc*, *vcv, ...*
  - Ví dụ: là helgoret, là juttelon; không phải: przbqxdfl, zxrptglfn
- Vấn đề: số lượng quá ít
- Giải pháp: băm khoá
  - Cho khóa dài đi qua hàm băm và chuyển đổi thành chuỗi ký tự in được.
  - Sử dụng chuỗi ký tự này làm mật khẩu

Lựa chọn của người sử dụng

- Vấn đề: người sử dụng chọn những mật khẩu dễ đoán
  - Dựa trên nên tài khoản, tên NSD, tên máy tinh, tên địa điểm, ...
  - Các từ có trong từ điển (từ ngược lại, các vị trí viết hoa, các ký tự kiểm soát, kết hợp hay phân tách , các từ trong kinh thánh Torah/Bible/Koran/…)
  - Quá ngắn, chỉ có chữ số, chỉ có chữ cái, ...
  - Số bằng lái xe, bí danh, số bảo hiểm xã hội, ...
  - Các đặc điểm cá nhân hoặc điểm nhạy cảm (tên thú cưng, bí danh, đặc điểm nghề nghiệp, ...)

Lựa chọn mật khẩu tốt

- “LIMm*2^Ap”
  - Names of members of 2 families
- “OoHeO/FSK”
  - Second letter of each word of length 4 or more in third line of third verse of Star-Spangled Banner, followed by “/”, followed by author’s initials
- What’s good here may be bad there
  - “DMC/MHmh” bad at Dartmouth (“Dartmouth Medical Center/Mary Hitchcock memorial hospital”), ok here
- Why are these now bad passwords? ☹

Kiểm tra chủ động mật khẩu

- Phân tích mật khẩu để xác định mật khẩu tốt.
  - Luôn được gọi
  - Có thể phát hiện, từ chối những mật khẩu yếu (yếu theo từng ngữ cảnh phù hợp)
  - Phân biệt trên cơ sở người dùng và từng bên
  - Cần đối sánh trên từ
  - Cần thực hiện các chương trình con để sử dụng kết quả
    - Ví dụ như kiểm tra chính tả
  - Dễ dàng cài đặt và tích hợp vào hệ thống chọn mật khẩu

Salting

- Mục tiêu: các tấn công từ điển chậm
- Phương pháp: xáo trộn hàm băm sao cho:
  - Tham số kiểm soát hàm băm nào sẽ được sử dụng;
  - Tham số khác nhau đối với mỗi mật khẩu;
  - Cho trước *n* mã băm mật khẩu, và do đó sẽ có *n* salts, cần phải băm để đoán *n*

Ví dụ

- Phương pháp Vanilla UNIX
  - Sử dụng DES để mã thông điệp 0 với mật khẩu làm khóa; lặp 25 lần
  - Xáo trộn E bảng trong DES bằng một trong 4096 cách
    - 12 bit của salt đảo các vị trí 1–11 với các vị trí 25–36
- Phương pháp tương ứng
  - Sử dụng salt như là phần đầu của đầu vào đưa vào hàm băm

Trường hợp Unix

- Hàm băm tiêu chuẩn của hệ UNIX
  - Băm các mật khẩu thành chuỗi 11 ký tự sử dụng một trong 4096 hàm băm
- Hệ thống xác thực định danh:
  - *A* = { xâu 8 ký tự hoặc ít hơn }
  - *C* = { 2 ký tự hash id || 11 ký tự băm }
  - *F* = { 4096 phiên bản biến thể của DES }
  - *L* = { *login*, *su*, … }
  - *S* = { *passwd*, *nispasswd*, *passwd+*, … }

Đoán qua *L*

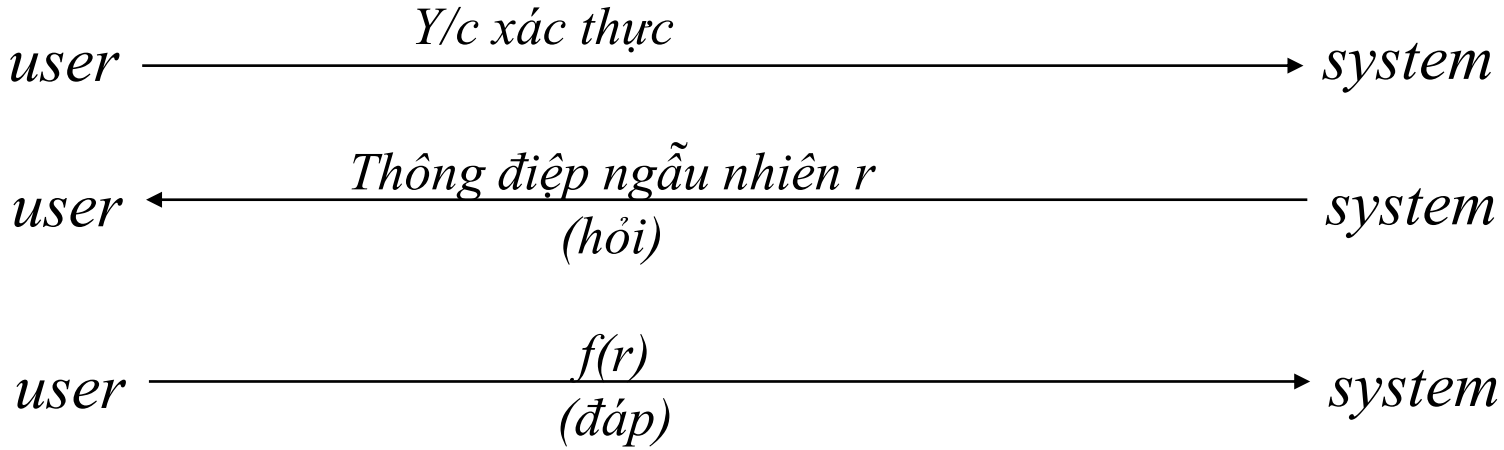
- Không thể ngăn chặn
  - Nếu không, người sử dụng hợp lệ không thể đăng nhập
- Làm chậm lại
  - Quay lui
  - Gián đoạn
  - Vô hiệu hoá
    - Cần rất cẩn thận với tài khoản quản trị !
  - Cầm giữ
    - Cho phép đăng nhập, nhưng giới hạn các hoạt động.

Thời hạn sử dụng mật khẩu

- Bắt buộc NSD thay đổi mật khẩu khi thời gian hiệu lực hết
  - Làm cách nào để bắt NSD không sử dụng lại mật khẩu
    - Lưu lại những mật khẩu trước đó
    - Khóa việc thay đổi trong một khoảng thời gian.
  - Cho NSD thời gian để nghĩ ra các mật khẩu tốt
    - Không bắt NSD thay đổi mật khẩu trước khi họ có thể đăng nhập vào hệ thống
    - Báo trước cho NSD thời gian hết hạn mật khẩu

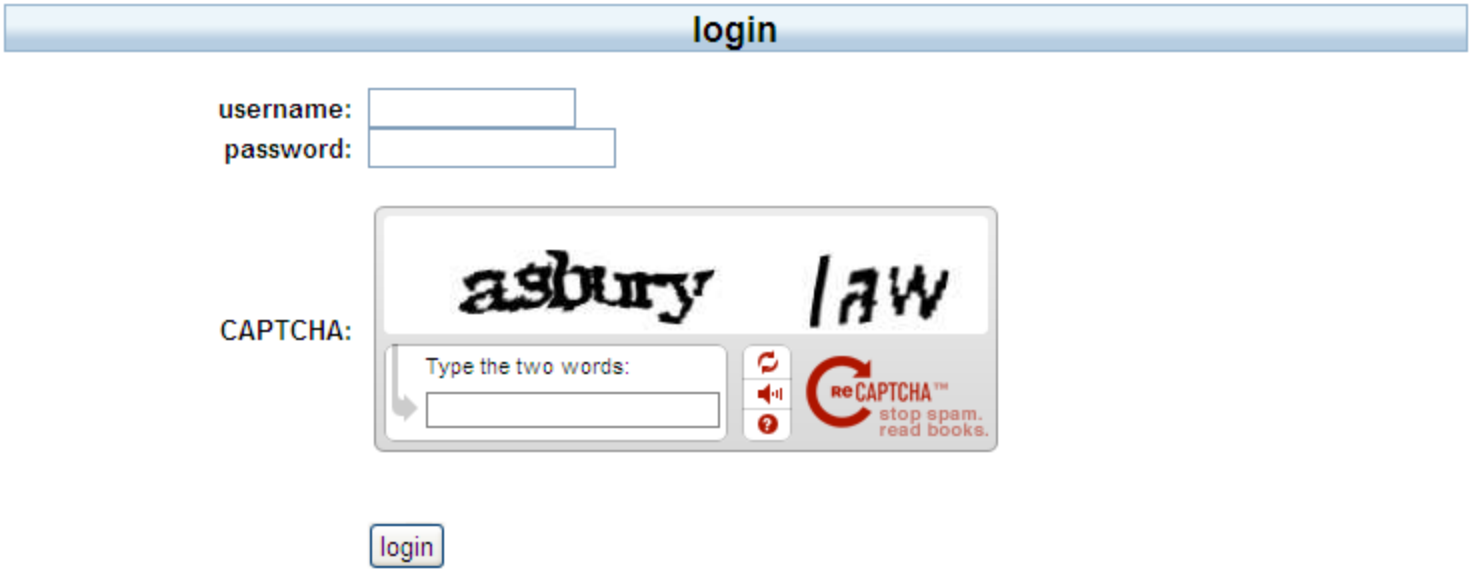
Giao thức Hỏi-đáp

- Người sử dụng, hệ thống chia sẻ hàm bí mật f (thực tế, f là hàm đã biết với những tham số chưa biết, như khóa mật mã)



Thuật toán Pass

- Quá trình hỏi-đáp với hàm *f* là bí mật
  - Câu hỏi là xâu ký tự ngẫu nhiên
  - Câu trả lời là một hàm của xâu ký tự đó
  - Thường sử dụng kết hợp với mật khẩu cố định và sử dụng lại.



Mật khẩu một lần

- Mật khẩu chỉ sử dụng một lần
  - Sau khi đã sử dụng, mật khẩu trở thành không tác dụng.
- Cơ chế Hỏi-đáp
  - Lời hỏi là một số để xác thực; trời đáp là mật khẩu tương ứng với số xác thực cụ thể.
- Vấn đề:
  - Sự đồng bộ giữa NSD, hệ thống
  - Tạo sinh các mật khẩu tốt và ngẫu nhiên
  - Vấn đề phân phối mật khẩu

S/Key

- Sơ đồ mật khẩu sử dụng một lần theo ý tưởng của Lamport
- *h* hàm băm một chiều (ví dụ: MD5 hoặc SHA-1)
- Người sử dụng chọn giá trị khởi tạo *k*
- Hệ thống tính toán :

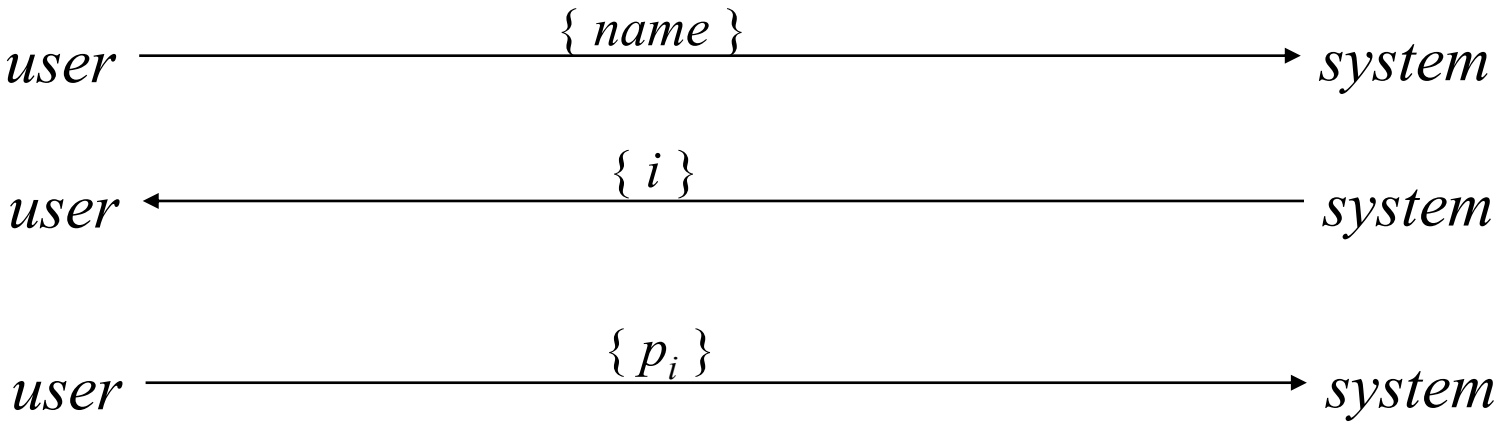
$$h(k) = k_1,\ h(k_1) = k_2,\ \ldots,\ h(k_{n-1}) = k_n$$

- Mật khẩu được xác định theo trật tự ngược lại:

$$p_1 = k_n,\ p_2 = k_{n-1},\ \ldots,\ p_{n-1} = k_2,\ p_n = k_1$$

Giao thức S/Key

Hệ thống lưu số lượng cực đại các giá trị xác thực n, số ứng với lần xác thực tiếp theo là i, mật khẩu sử dụng đúng cuối cùng là p_{i-1}.



Hệ thống tinh $h(p_i) = h(k_{n-i+1}) = k_{n-i+2} = p_{i-1}$. Nếu trùng khớp với thông tin được lưu, hệ thống sẽ thay thế p_{i-1} bằng p_i và tăng i.

Hệ thống phần cứng

- Dựa trên thẻ bài (token)
  - Để tính các câu trả lời ứng với câu hỏi.
    - Có thể được mã hoặc băm câu hỏi.
    - Có thể yêu cầu mã PIN của NSD
- Dựa trên thời gian
  - Mỗi phút sẽ ứng với một số khác nhau được đưa ra.
    - Máy tinh sẽ biết giá trị nào sẽ được đưa ra.
  - NSD nhập số tương ứng và mật khẩu cố định

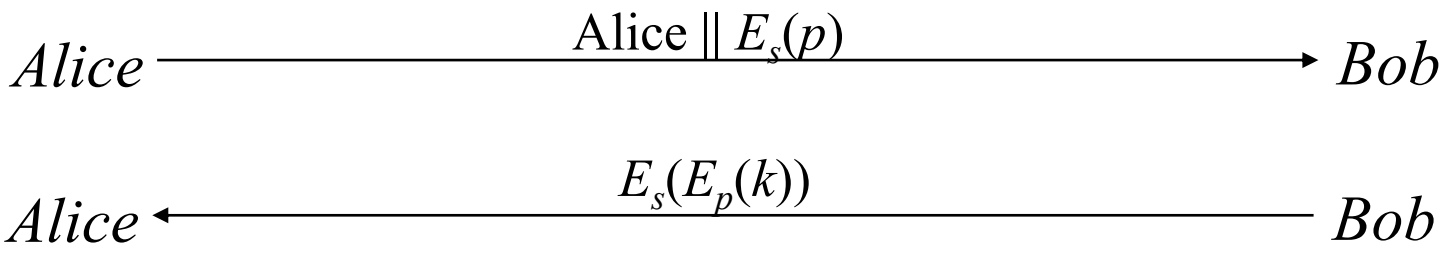
C-R và tấn công từ điển

- Tương tự như trường hợp mật khẩu cố định
  - Bên tấn công biết câu hỏi *r* và trả lời *f*(*r*); nếu *f* là hàm mật mã, có thể thử các khóa khác nhau
    - Có thể chỉ cần *dạng* của câu trả lời; bên tấn công có thể chỉ ra giá trị thử đúng hay không bằng cách kiểm tra xem chuỗi giải mã có định dạng đúng hay không
    - Ví dụ: Kerberos V4 sử dụng DES, với khóa 20 bit ngẫu nhiên; bên tấn công Purdue có thể đoán khóa nhanh chóng vì thẻ bài được giải mã có một tập hợp bit cố định tại một số vị trí.

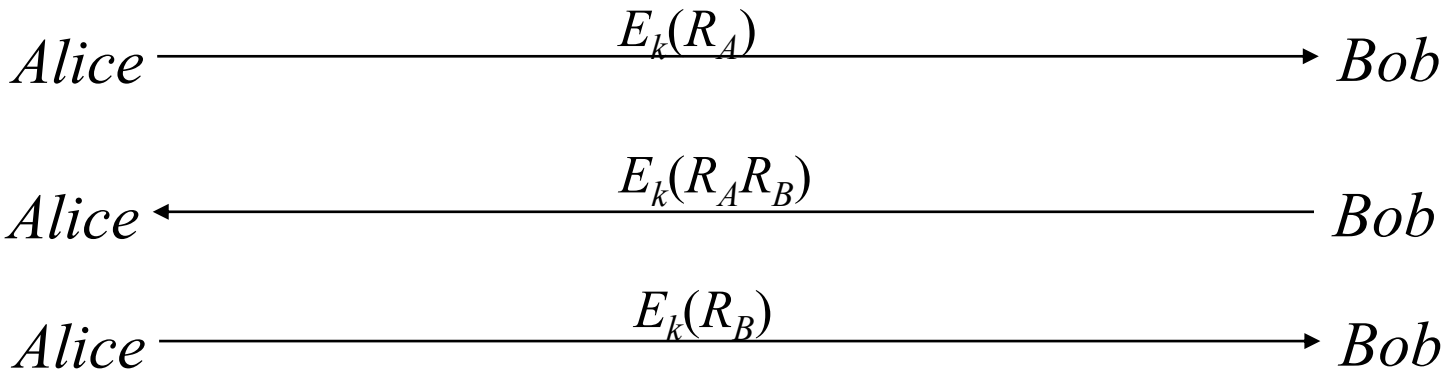
Trao đổi khóa được mã hóa

- Chống lại tấn công từ điển off-line
- Ý tưởng: các câu hỏi ngẫu nhiên được mã mật, bên tấn công không thể kiểm chứng được việc giải mã đúng câu hỏi.
- Giả sử Alice, Bob chia sẻ mật khẩu bí mật *s*
- Alice cần tạo sinh cặp khóa ngẫu nhiên với khóa công khai ngẫu nhiên *p* và khóa riêng tương ứng *q*
- Tương tự, *k* là khóa phiên được tạo sinh ngẫu nhiên, và R_A và R_B là các câu hỏi được sinh ngẫu nhiên

Giao thức EKE



Alice, Bob chia sẻ khóa phiên sinh ngẫu nhiên k



Sinh trắc

- Xác định tự động các đặc trưng sinh học, hành vi xác định một cá nhân
  - Vân tay: lấy bằng các kỹ thuật quang học hoặc điện tử
    - Ánh xạ vân tay vào đồ thị đặc trưng, sau đó so sánh với vaantay đã lưu trữ trong CSDL
    - Vấn đề: việc xác định có thể không chính xác, cần sử dụng các thuật toán đối sánh xấp xỉ
  - Giọng nói: xác định hoặc nhận dạng người nói
    - Kiểm tra: sử dụng các kỹ thuật thống kê để kiểm định các giả thuyết về người nói
    - Nhận dạng: xác định nội dung của các câu nói (không phụ thuộc người nói)

Những đặc trưng khác

- Có thể sử dụng những đặc trưng sinh trắc khác như:
  - Mắt: các vân của mống mắt là đặc thù cho mỗi người
    - Đo các mẫu, xác định những điểm khác biệt có là ngẫu nhiên !? Hoặc tìm sự tương quan giữa các hình ảnh dựa trên kiểm định thống kê.
  - Khuôn mặt: hình ảnh hoặc những đặc trưng chuyên biệt như khoảng cách từ mũi tới cằm.
    - Độ sáng, các hướng nhìn khuôn mặt, các nhiễu khác có thể cản trở việc xác định đó
  - Kiểu gõ phím cũng có thể là đặc trưng
    - Những khoảng thời gian gõ phím, áp lực, độ dài gõ phím, phím nào bị kẹt, ...
    - Sử dụng kiểm định thống kê

Chú ý

- Các biện pháp này có thể bị lừa
  - Giả thiết rằng thiết bị sinh trắc làm việc tốt *trong môi trường sử dụng*.
  - Quá trình gửi dữ liệu tới bên kiểm tra không bị tấn công giả mạo và đúng đắn.

Vị trí

- Nếu ta biết vị trí của NSD, quá trình xác thực danh tính sử dụng cả thông tin vị trí NSD
  - Cần có phần cứng chuyên biệt để định vụ NSD
    - Sử dụng thiết bị GPS (global positioning system) để cung cấp vị trí xác định NSD
    - Trạm sử dụng LSS (location signature sensor) để lấy thông tin vị trí của NSD

Những phương pháp phức hợp

- Ví dụ: dịch vụ xác định vị trí cần thực thể có cả LSS và GPS,
- Có thể sử dụng những phương pháp khác nhau cho những công việc khác nhau
  - Vì NSD thực hiện ngày càng nhiều các hoạt động nhạy cảm, do đó các cần nhiều phương pháp xác thực nghiêm ngặt khác nhau. File mô tả các phương pháp xác thực yêu cầu.
    - Trong đó gồm cả các thông tin kiểm soát truy cập (như thời gian trong ngày, ...), tài nguyên, và các yêu cầu thay đổi mật khẩu, ...
  - Các mô-đun xác thực có thể Plug

PAM

- Ý tưởng: khi chương trình cần xác thực, chương trình sẽ kiểm tra kho dữ liệu trung tâm để xác định phương pháp sử dụng:
- Gọi hàm thư viện: *pam_authenticate*
  - Tru cập file với tên của chương trình trong */etc/pam_d*
- Các mô-đun thực hiện kiểm tra xác thực
  - *sufficient*: thành công nếu mô-đun thành công
  - *required*: không thành công nếu mô-đun thất bại, nhưng tất cả các mô-đun được yêu cầu được thực hiện trước khi có thông báo thất bại.
  - *requisite*: tương tự *required*, nhưng không kiểm tra tất cả các mô-đun
  - *optional*: được gọi chỉ khi tất cả các mô-đun trước bị thất bại.

Ví dụ về PAM File

```
auth  sufficient  /usr/lib/pam_ftp.so

auth  required    /usr/lib/pam_unix_auth.so use_first_pass

auth  required    /usr/lib/pam_listfile.so onerr=succeed \
                        item=user sense=deny file=/etc/ftpusers
```

Với ftp:

1. Nếu NSD là “anonymous”, trả lại OK; Nếu không phải - đặt PAM_AUTHTOK - mật khẩu, PAM_RUSER - tên NSD và fail
2. Kiểm tra mật khẩu trong PAM_AUTHTOK có phải của NSD trong PAM_RUSER; Nếu không phải, fail
3. Kiểm tra xem NSD trong PAM_RUSER có tên trong /etc/ftpusers hay không; Nếu có, fail; Nếu không tìm thấy thì thành công.

Những điểm quan trọng

- Xác thực định danh không phải là mật mã
  - Cần phải xem xét các thành phần của hệ thống
- Mật khẩu
  - Cung cấp cơ sở cho hầu hết các dạng xác thực định danh
- Tầm quan trọng của giao thức
  - Giao thức làm cho việc giả mạo khó khăn hơn
- Các phương pháp xác thực danh tính có thể dung kết hợp
  - Ví dụ: PAM

Kerberos

- Là giao thức xác thực trong mạng máy tính
  - Cho phép các nút mạng tương tác với nhau qua mạng mở, và xác minh các thực thể với nhau một cách an toan.
- Hoạt động của giao thức:
  - Sinh viên tự học. Tài liệu trên mạng Internet

ĐẠI HỌC BÁCH KHOA

25 YEARS ANNIVERSARY SOICT

VIỆN CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG

SCHOOL OF INFORMATION AND COMMUNICATION TECHNOLOGY

Thank you for your attentions!



soict.hust.edu.vn/ fb.com/groups/soict